

University of Wasit

College of CS & IT

Academic Term: Fall 2026

Instructor: Asst. Prof. Dr. Huda Lafta Majeed

Master Studio · CS502 Cyber Security

وثيقة المراجعة والتلخيص الأكاديمي

Comprehensive Lecture Summary & Review



Cyber Security — Week 01 Master Note

Chapter 1–6: Introduction to Cybersecurity

Built for: Dr. Huda Lafta Majeed's exam style — verified 2026-09-18 Source: 02_Raw_Materials/Week 01 - ANNOTATED (student) - Introduction to Cybersecurity.pdf (the doctor's own lecture material) Decode of her method: Week_01_Annotation_Map.md Excluded: Chapter 7 (Case Studies) — the doctor said she does not want it.

⚡ كيف تقرأ هذي الملاحظة (اقرأي أول)

الدكتورة عندها نمطين للسؤال — وإنت لازم تعرف تفرّق بينهم قبل كل شي:

شلون تجاوب	شنو تريد	إذا السؤال...
اكتب المعادلة → عوّض → اطلع الناتج → فسّر الناتج بسطر	تطبّق المعادلة	بيه أرقام
خطوة بخطوة → سمّي ركن CIA → وبالقوس اكتب التقنيات	تحليل	ما بيه أرقام (سيناريو)

والقوس هو المفتاح — بدون التقنيات داخل القوس، الجواب ناقص.

1 الفصل الأول: تعريف الأمن السيبراني

التعريف: حماية الأنظمة والشبكات والتطبيقات والبيانات من التهديدات الإلكترونية والوصول غير المصرّح به والضرر. يشمل جوانب تقنية + قانونية + إدارية + اجتماعية.

النطاق: من الأجهزة الشخصية → أنظمة المؤسسات → البنية التحتية الوطنية الحرجة.

التطور التاريخي (إنت كاتب "مراحل تطوير السايبر سكيروتي" جنبه):

المرحلة	الفترة
أول ذكر مع ARPANET وأجهزة الـ mainframe	1960s
ظهور الفيروسات والديدان ومضادات الفيروسات	1980s–90s
الأمن السيبراني يصير جزء أساسي من التجارة الإلكترونية والمصرفية	2000s
Zero Trust · IoT · Ransomware · APT · الذكاء الاصطناعي	2010s–الآن

الأهمية: مرتبط مباشرة بـ الأمن الوطني · الاستقرار الاقتصادي · حماية الخصوصية.

■ المعادلة ① — السايبر كم مشكلة تحسين (إنت محوَّطها)

$$\min R = \sum_{i=1}^n P_i \cdot I_i - \sum_{j=1}^m C_j$$

الرمز	المعنى
P_i	احتمال حصول التهديد i
I_i	تأثير التهديد i
C_j	الاستثمار في ضابط الأمان j

الفكرة: تقليل الخطر إلى الحد الأدنى، مع تعظيم الاستثمار الأمني. يعني **مو تزيد حماية و خلاص — لازم توازن.**

✦ **قاعدة الدكتور:** "إذا الناتج ازداد عن الـ 100 يعني اكو استثمار، وإذا اقل من 100 يعني مفيش استثمار"  هي كالتها — وهاي هي القاعدة. سجّلها كما هي. لا تسألها ولا تجادل — د. هدى مقررة قسم الدراسات العليا بالكلية، وكلامها هو المرجع.

💡 **ملاحظة للفهم فقط (مو للنقاش):** اعتبرها عتبة قرار (decision threshold) — فوق 100 = الاستثمار مجدي، تحتها = مو مجدي. هذا كل اللي تحتاجه للامتحان.

2 الفصل الثاني: الأهمية والنطاق

المستويات الأربعة:

المستوى	شئو يحمي
Individuals	الأجهزة الشخصية · الإيميلات · السوشيال ميديا · بيانات المصرف
Enterprises	استمرارية العمل · ثقة العملاء · الامتثال القانوني
Governments	الأمن الوطني · الدفاع · البنية التحتية للحكومة الإلكترونية
Global Trade	التجارة الرقمية عبر الحدود · الأنظمة المالية

المجالات الأساسية (إنت كاتب "المجالات الأساسية للسايبر" و"عدد مجالات السايبر قابلة للزيادة"):

#	المجال	أدواته
1	Network Security	firewalls · IDS/IPS
2	Application Security	secure coding · OWASP standards
3	Cloud Security	encryption · IAM · virtualization
4	IoT Security	lightweight encryption · anomaly detection
5	Mobile Security	sandboxing · malware detection
6	ICS Security	حماية أنظمة التحكم الصناعي

✓ ملاحظتك صحيحة ومهمة: "عدد مجالات السايبر قابلة للزيادة" — القائمة **مو مقفلة**. لو جاب سؤال "شنو المجالات الأساسية" اكتب الستة، واذكر إنها قابلة للتوسّع (Supply-Chain Security, AI Security, ...).

■ المعادلة ② — التعرّض للخطر (محوّطة)

$$R(t) = \sum_{i=1}^n P_i(t) \cdot I_i(t)$$

المعنى: الخطر المتوقع عند زمن t ، مجموع على كل التهديدات.

🔗 ملاحظتك: "السؤال ماله بيه وقت بس مو مفيد... غير مستخدم بس علمود نعرف هذا القانون" ✓ إنت محق. الدكتورة قالت: "بس نعرف هذا القانون هنا يستخدم" — يعني **وعي سطحي فقط**. لا تحفظها حفظ، بس اعرف إنها موجودة.

3 الفصل الثالث: ثالوث CIA — ● هذا أهم شي بالوحدة

ليش؟ لأنه المفردات اللي راح تكتبها داخل القوس بكل سؤال سيناريو. بدونها الجواب ناقص.

★ جدول الحفظ الإلزامي

الركن	التعريف	التقنيات (تُكتب بالقوس)
Confidentiality 🛡️ السريّة	منع الوصول غير المصرّح به للبيانات	encryption · access controls · VPNs
Integrity ✓ السلامة	ضمان إن البيانات دقيقة وغير معدّلة	hashing (SHA-256) · digital signatures · version control
Availability ⚡ التوفر	ضمان إن الموارد متاحة وقت الحاجة	redundancy · load balancing · DDoS mitigation

احفظ الجدول كامل — الأعمدة الثلاثة. هذا مو اختياري.

■ المعادلة ③ — دالة المنفعة الأمنية (محوّطة)

$$U(C, I, A) = \alpha C + \beta I + \gamma A$$

الرمز	المعنى
C, I, A	قيم مُنَظَّمة (1-0) للسريّة والسلامة والتوفر
α, β, γ	أوزان الأهمية لنظام معيّن

● النقطة اللي الدكتور شددت عليها (كتبتها بالأحمر):

"In healthcare, confidentiality (α) has higher weight than availability."

يعني: α, β, γ مو ثابتة — تتغير حسب المجال:

المجال	الركن الأثقل	ليش
🏥 Healthcare	Confidentiality (α)	سجلات المرضى — الخصوصية فوق كل شي
🏦 Banking	Integrity (β)	لو تغيّر رقم بالحساب → كارثة
🚑 Emergency services	Availability (γ)	النظام لازم يشتغل دائماً

🎯 هذا جواب سؤال "ليش الأوزان تختلف" — جهّزه كامل، لأنه نموذج سؤال محتمل جداً.

4 الفصل الرابع: مشهد التهديدات

الأنواع:

النوع	الوصف
Malware	فيروسات · ديدان · أحصنة طروادة · Ransomware
Phishing & Social Engineering	استغلال الثقة البشرية
Insider Threats	موظفين يسيئون استخدام صلاحياتهم
APTs	مدعومة من دول · خفية · طويلة المدى
IoT Attacks	Botnets — مثال: Mirai

الاتجاهات العالمية 2023-2024 (إنت كاتب "ترندات الاختراقات بـ 2023 2024"): - أضرار الـ Ransomware تتجاوز \$20 مليار - هجمات السحابة ترتفع بسبب الأخطاء الإعدادية (misconfigurations) - هجمات مدعومة بالذكاء الاصطناعي تنمو

■ المعادلة ④ — سطح الهجوم (محوّطة)

$$AS = \sum_{j=1}^m (E_j \cdot V_j \cdot A_j)$$

الرمز	المعنى
E_j	عدد نقاط الدخول المكشوفة
V_j	شدة الثغرة (CVSS score)
A_j	قيمة الأصل (asset value)

المعنى: تقيس "شكك النظام قابل للهجوم". كل ما زاد → سطح هجوم أكبر.

🔗 ملاحظتك: "دراسة الثغرات" — صحيح، هذي معادلة قياس الثغرات المكشوفة.

5 الفصل الخامس: المخاطر والثغرات والاستغلالات

المفهوم	التعريف
Risk	دالة الاحتمال × التأثير
Vulnerabilities	نقاط ضعف برمجية أو عتادية أو بشرية (CVEs · OWASP Top 10)
Exploits	أدوات/طرق تستغل الثغرات

نماذج تقييم المخاطر (احفظ الأسماء + توسّعها):

النموذج	التوسّع
OCTAVE	Operationally Critical Threat, Asset, and Vulnerability Evaluation
FAIR	Factor Analysis of Information Risk
NIST RMF	Risk Management Framework

المعادلة ⑤ — توزيع احتمال الخطر

$$P(R > r) = 1 - F(r)$$

المعنى: احتمال إن الخطر يتجاوز قيمة معيّنة r .

🔗 ملاحظتك: "الـ $F(r)$ محصورة بين 0 و 1" — صحيح تماماً. لأنها دالة توزيع تراكمي (CDF)، فمجالها دائماً $[0, 1]$. وهذي هي فائدة المعادلة: $1 - F(r)$ يعطيك احتمال الذيل.

6 الفصل السادس: التطور والسياسات

المرحلتان: - Early (1960s–1990s): دفاع محيطي — Modern - antivirus · firewalls (2000s–الآن): سحابة · IoT · موبايل · هجمات مدعومة بالذكاء الاصطناعي

السياسات والأطر:

الإطار	الجهة	يغطي
GDPR	الاتحاد الأوروبي	حماية البيانات والخصوصية
HIPAA	أمريكا	حماية معلومات الرعاية الصحية
NIST / ISO 27001	دولية	المعايير الدولية

المنظورات العالمية: - EU - ENISA · GDPR → US - NIST CSF · Federal Cybersecurity Strategy - EU - National Cybersecurity Councils → Middle East

المعادلة ⑥ — مؤشر الامتثال للسياسات

$$PCI = \frac{\sum_{k=1}^n w_k \cdot c_k}{\sum_{k=1}^n w_k}$$

الرمز	المعنى
c_k	مستوى الامتثال للمتطلب k (1-0)
w_k	وزن أهمية المتطلب

📌 ملاحظتك: "الالتزام بالسياسة او القوانين اوالمدري شنو" الجواب: هي متوسط موزون — تقيس شكذ المؤسسة ملتزمة بمتطلبات السياسة، مع إعطاء المتطلبات الأهم وزناً أكبر. الناتج بين 0 و 1 (لو ضربته بـ100 يصبح نسبة مئوية).

✖ الفصل السابع — خارج الامتحان

GDPR Enforcement · Colonial Pipeline · Stuxnet — الدكتور كالت ما تريده. لا تضيع وقت عليه.

🎯 تدريب على السيناريوهات (بأسلوبها بالضبط)

القاعدة: خطوة خطوة → سمي ركن CIA → وبالقوس اكتب التقنيات. (ملاحظة: كل السيناريوهات هذي من عندي كتدريب — مو من المحاضرة).

سيناريو 1 — (نفس مثال إنت كتبتة)

عميل بمصرف شاف حسابه نقص 100,000 دولار مرة وحدة. اتصل بالمدير. المدير حقّق وطلع السبب مجرد خلل بالبرنامج. صلّحه ورجّع المبلغ.

الجواب: 1. المستخدم شاف بياناته تغيّرت → Integrity (version control ,digital signatures ,hashing SHA-256) 2. اتصلنا وعرفنا إن النظام بيه مشكلة → Availability (DDoS mitigation ,load balancing ,redundancy) 3. انصلّح ورجع المبلغ → انتهت المشكلة

سيناريو 2 — مستشفى

مستشفى، سجلات المرضى صارت تظهر لمستخدم غير مصرّح له من قسم ثاني. التحقيق بيّن إن حساب موظف قديم لا زال فعّال.

الجواب: 1. بيانات المرضى انكشفت لغير المصرّح لهم → **Confidentiality** (VPNs , access controls , encryption) 2. السبب: حساب قديم ما انعطّل → **Access Control failure** — ينحل بـ **access controls** + مراجعة دورية للحسابات 3. الإصلاح: تعطيل الحساب + تدقيق الصلاحيات

سيناريو 3 — جامعة

نظام التسجيل بالجامعة وقع بوقت التسجيل، وآلاف الطلاب ما قدروا يسجلوا.

الجواب: 1. النظام ما كان متاح وقت الحاجة → **Availability** (DDoS mitigation , load balancing , redundancy) 2. احتمال إنه **DDoS** — لو كذلك: **DDoS mitigation** 3. الإصلاح طويل المدى: **redundancy** (سيرفرات احتياطية) + **load balancing** لتوزيع الحمل

سيناريو 4 — متجر إلكتروني

عميل لاحظ إن سعر المنتج بالفاتورة تغيّر بعد ما أكّد الطلب.

الجواب: 1. البيانات تغيّرت بعد التأكيد → **Integrity** (version control , digital signatures , hashing SHA-256) 2. **version control** يبيّن متى تغيّر السعر ومنو غيّرّه 3. لو السبب خلل بالنظام → **Availability** (النظام ما كان يشتغل صح)

📋 خلاصة قبل الامتحان

#	شئ لازم تعرفه	مستواه
1	ثالوث CIA + التقنيات (3 أعمدة)	● حفظ إلزامي
2	ليش α, β, γ تختلف حسب المجال (healthcare/banking/emergency)	● حفظ + مثال
3	4 معادلات المحوطة — متى تحسب ومتى تشرح	● فهم + تطبيق
4	أنواع التهديدات + اتجاهات 2023–2024	● حفظ خفيف
5	نماذج تقييم المخاطر (NIST RMF · FAIR · OCTAVE)	● حفظ الأسماء + التوسّع
6	المجالات الستة (وقابلة للزيادة)	● حفظ
7	GDPR · HIPAA · NIST/ISO 27001	● حفظ
8	$R(t)$ — بس اعرف إنها موجودة	○ سطحي
9	الفصل السابع (Case Studies)	✗ خارج الامتحان

وشكل الامتحان اليومي: كتابي/مقالتي · ~10 دقائق · غالباً أول المحاضرة · درجة خفيفة (تريد بس تتأكد إنك قرّيت).

ملحق: شرح معادلة سطح الهجوم AS بالتفصيل الكامل

ليش هذا الملحق؟ أبو الحسن قال: "المعادلة ولا فهمت شبيها... ولا فهمت السؤال شلون يجي عليها ولا شلون احل". فهذا شرح كامل — مو مختصر.

1 أول شي: شنو يعني "سطح الهجوم" (Attack Surface)؟

تخيّل بيت. "سطح الهجوم" = كل الطرق اللي يكدر الحرامي يدخل منها: - الباب الرئيسي - الشبابتك - باب الكراج - السطح - النافذة المكسورة

كل نقطة دخول = نقطة لازم تحميها.

وبالنظام الحاسوبي: نقاط الدخول هي المنافذ (ports) · الخدمات (services) · واجهات API · حسابات المستخدمين.

🎯 الفكرة الجوهرية: كل ما زادت نقاط الدخول، صعب تحمي النظام. فالهدف تقلّلها.

2 ليش ضرب (x) مو جمع (+)؟ — هذا أهم سؤال

الجواب: الضرب يعني "لازم الثلاثة موجودين سوا حتى يصير الخطر". لو أي واحد منهم = صفر → الناتج صفر.

شنو يعني	$E \times V \times A$	A	V	E	الحالة
● خطر حقيقي	40,000	1000	8	5	مكشوف + ثغرة + بيانات مهمة
✅ محصّن	0	1000	0	5	مكشوف بس ما بيه ثغرة
✅ ما يوصله أحد	0	1000	8	0	بيه ثغرة بس مسكّر
✅ ما يستاهل ينخرق	0	0	8	5	مكشوف + ثغرة بس فاضي

🔑 الخلاصة: الخطر يحتاج الثلاثة سوا: - بلا نقطة دخول → ما يكدر يوصل - بلا ثغرة → ما يكدر ينخرق - بلا قيمة → ما عنده سبب ينخرق

? لو كانت جمع (+): السيرفر المحصّن ($V = 0$) كان يعطي ناتج كبير — وهذا منطقياً غلط. المحصّن مو خطر. فالضرب هو الصح.

3 الرموز — واحد واحد بالتفصيل

الرمز	الاسم الكامل	شنو يعني بالضبط	مينن تجيب قيمته	مجاله
E_j	Exposed entry points	عدد المنافذ/الخدمات المكشوفة للمكوّن j	تعدّها بنفسك (بورتات مفتوحة · APIs · حسابات)	0, 1, 2, 3... (عدد صحيح)
V_j	Vulnerability severity	شدة الثغرة — شكّد خطيرة	من CVSS score (معيّار عالمي)	0.0 – 10.0
A_j	Asset value	قيمة الأصل — شكّد هذا المكوّن مهم	تقدير مالي/تشغيلي (قيمة البيانات · أهمية السيرفر)	أي رقم (يمكن ملايين)
j	index	رقم المكوّن (سيرفر 1 · سيرفر 2...)	—	$1 \rightarrow m$
m	عدد المكوّنات	جم مكوّن عدنا	تعدّهم	—

$\sum$ (سيغما) = "اجمع على كل المكوّنات" — يعني: لكل مكوّن، احسب $E \times V \times A$ لحاله، وبعدها اجمع النواتج.

4 شنو يعني CVSS؟ (لأنه أساس V_j)

CVSS = Common Vulnerability Scoring System — معيار عالمي يقيس خطورة الثغرة من 0 إلى 10:

المدى	التصنيف
0.0	ماكو ثغرة
0.1 – 3.9	Low (منخفضة)
4.0 – 6.9	Medium (متوسطة)
7.0 – 8.9	High (عالية)
9.0 – 10.0	Critical (حرجة)

فلو $V_j = 8 \rightarrow$ الثغرة عالية الخطورة. ولو $V_j = 9.8 \rightarrow$ حرجة.

5 السؤال شلون يجي؟ — ثلاثة أشكال

الشكل 1 — سؤال أرقام (تحسب)

"عندك مكوّنات: الأول $A = 100, V = 8, E = 3$ ، والثاني $A = 300, V = 5, E = 2$. احسب AS ."

$\rightarrow$ تضرب سطر سطر، وبعدها تجمع. خلاص.

الشكل 2 — سؤال بلا أرقام (تشرح)

"شنو العوامل اللي ترفع سطح الهجوم؟" أو "شلون تقلّل سطح الهجوم؟"

→ تعدّ الثلاثة، تشرح كل واحد، وتقول إن الضرب يعني "لازم الثلاثة سوا".

الشكل 3 — سيناريو (تحلل)

"سيرفر قديم عليه 12 خدمة..."

→ تحدّد العوامل الثلاثة من القصة، تربطها بالمعادلة، وتقتترح حل.

6 شلون تحل — خطوة بخطوة (مثالنا)

المكوّن	E_j	V_j	A_j
1	3	8	100
2	2	5	300

الخطوة 1 — المكوّن الأول لحاله:

$$E_1 \times V_1 \times A_1 = 3 \times 8 \times 100 = 24 \times 100 = 2400$$

الخطوة 2 — المكوّن الثاني لحاله:

$$E_2 \times V_2 \times A_2 = 2 \times 5 \times 300 = 10 \times 300 = 3000$$

الخطوة 3 — اجمع النواتج:

$$AS = 2400 + 3000 = \boxed{5400}$$

7 ⚠ الأخطاء الشائعة (احذر منها بالامتحان)

الصح ✓	الغلط ✗
اضرب سطر سطر أول، وبعدها اجمع → 5400	تجمع الأعمدة عمودياً أول $(3+2) \times (8+5) \times (100+300) = 26,000$
A = قيمة الأصل — جزء أساسي من الضرب	تنسى تضرب بـ A_j
E = عدد (جم نقطة دخول) $\cdot V$ = شدة (0-10)	تخلط بين E و V
CVSS أقصاها 10	تحسب V أكبر من 10

8 الفحص المنطقي (تتأكد من جوابك)

يعني	إذا $AS \dots$
أحد العوامل صفر $\rightarrow$ (ماكو نقطة دخول) أو (ماكو ثغرة) أو (ماكو قيمة)	= صفر
النظام شبه محصّن، أو ما بيه شي يستاهل	صغير
مكوّن مهم + مكشوف + بيه ثغرة خطيرة $\rightarrow$ أولوية إصلاح	كبير

9 نقطة ذكية للسيناريو: أي عامل تحكّم بيه؟

شلون	شكد تقدر تتحكم بيه؟	العامل
سكّر بورتات · قلّل خدمات · network segmentation	☆☆☆ الأسهل والأرخص	E_j
تحديثات و patching (يعتمد على المطوّر)	☆☆ متوسط	V_j
ما يتغير — السيرفر بيقى مهم	☆ صعب	A_j

💡 لذلك: "شلون تقلّل سطح الهجوم؟" $\rightarrow$ الجواب الأقوى: قلّل E_j (نقاط الدخول) — لأنها الأسرع والأرخص.

بني 18-09-2026 بواسطة [Koko](#)، من مادة الدكتوراة نفسها + أجوبة أبي الحسن عن أسلوبيها.